

Fawtara ASP

Application Software Architecture

Accredited Service Provider platform for Oman's national e-invoicing framework
Operates as Corners 2 & 3 in the Peppol 5-Corner CTC model · Multi-tenant SaaS

Standard	Framework	Compliance	SLA Target	Version
OM PINT / UBL 2.1	Peppol 5-Corner CTC	ISO/IEC 27001:2022	99.9% Uptime	Draft v1.0 — March 2026

ARCHITECTURE LAYERS					
● 1 — External & Integration	● 2 — API Gateway & Security	● 3 — Core Application Services			
● 4 — Data & Storage	● 5 — Infrastructure & Observability	● 6 — Compliance & Governance			

Strategic Design Note — Configurability First
Several OTA specs are still pending as of March 2026 (QR code format, digital signature standard, B2C submission timeframe, final OM PINT schema). Affected components are marked CONFIGURABLE — hot-swappable modules that avoid code rework when final OTA specs are published.

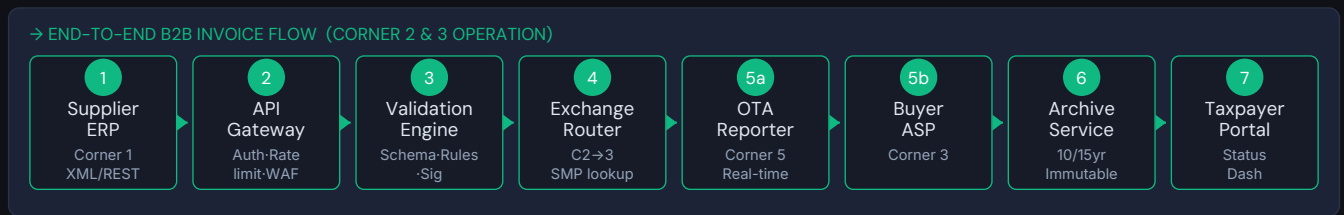
Prepared for:

Sohar International Bank — Fawtara ASP Software Project

Based on OTA official portal, consultation sessions Dec 2025–Mar 2026, Peppol framework documentation

End-to-End B2B Invoice Flow

Real-time B2B invoice traversing all 7 processing stages from Supplier ERP to Taxpayer confirmation. Target latency: <3 seconds end-to-end.



Strategic Design Note — Configurability First

Several OTA specifications are still pending as of March 2026:

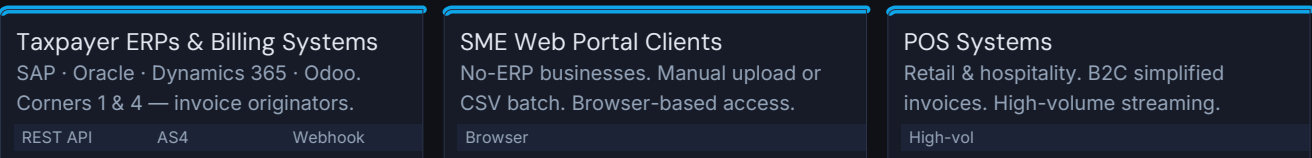
QR code format, digital signature standard (XAdES/CAdES), B2C submission timeframe,

and the final OM PINT schema version. Affected components are marked CONFIG — hot-swappable modules.

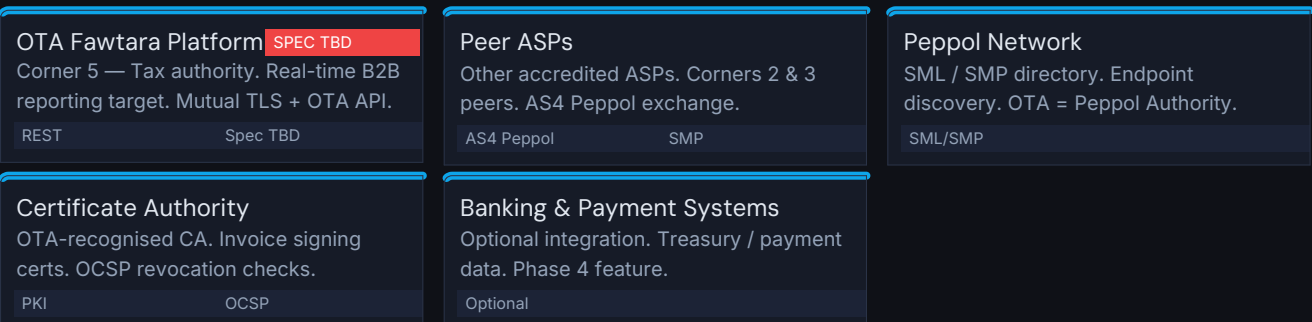
1 EXTERNAL SYSTEMS & INTEGRATION

Everything outside the ASP platform boundary

TAXPAYER SIDE (CORNERS 1 & 4)



OTA & PEPPOL NETWORK (CORNER 5)



API Gateway (OAuth 2.0)

OTA REQ

Rate limiting. JWT validation. API versioning. OAuth 2.0 / OIDC.

OAuth 2.0

JWT

Load Balancer

Layer 7 routing. Health checks. SSL termination. Traffic distribution.

L7

HA

Web Application Firewall

OWASP Top 10 protection. DDoS mitigation. Bot detection. Geo-filtering.

OWASP

DDoS

MFA Service

OTA REQ

TOTP — mandatory OTA requirement. Authenticator app. Per-user enforcement.

TOTP

RBAC Engine

Per-tenant isolation. Role-based access control. Least-privilege enforcement.

Role-based

TLS 1.3 Termination

OTA REQ

TLS — OTA requirement (no-minimum). Cert auto-rotation. OCSP stapling.

TLS 1.3

AS4 Peppol Endpoint

AS4 signing / encrypt. Corner 2/3 comms. Oxalis Phase 4.

AS4

Oxalis

3 CORE APPLICATION SERVICES

Invoice ingestion · Validation · Exchange · Reporting · Archiving

Primary pipeline: Invoice Ingestion → Message Queue → Validation Engine → Exchange Router → [OTA Reporter || Peer ASP] → Archive Service | Target: <3 sec B2B

A — INVOICE INGESTION

REST API Ingestion Service

OM PINT XML / JSON input. Sync ack
UUID + timestamp. Single invoice and
batch endpoints.

Node.js / Fastify OpenAPI 3.0

AS4 Peppol Receiver

Corner 3 operation. Receive invoices
from peer ASPs. AS4 protocol handler.

AS4

Portal Upload Handler

CSV / Web form / JSON. Schema
normalisation. SME-facing upload
channel.

SME support

B — VALIDATION ENGINE (CONFIGURABLE — SCHEMA-DRIVEN)

Schema Validator

CONFIG

OM PINT / UBL 2.1 XSD. Hot-reload — no
downtime updates. Rejects with error
codes.

XSD JSON Schema Spec TBD

Business Rules Engine

OTA Data Dictionary rules. VAT math /
field checks. Config-driven rule sets —
Drools or custom.

Drools Configurable

Duplicate & Hash Detector

UUID dedup / PIH chain. Sequence
validation. Redis bloom filter for fast
lookups.

Redis

Digital Signature Verifier

CONFIG

XAdES / CAAdES standard TBD. OCSP
cert validation. Pluggable signature
library.

Spec TBD Standard TBD

C — EXCHANGE ROUTER (CORNER 2 → 3 LOGIC)

Invoice Router

B2B → Buyer ASP via Peppol. B2C →
OTA only. RCM / VAT group routing.
State machine.

State machine

SMP Lookup Service

Buyer ASP discovery via Peppol SMP.
Fallback to B2C flow if no SMP record.

Peppol SMP

Acknowledgement Manager

Corner 3 ack tracking. Rejection →
re-issue. <24hr ack window.
Event-driven.

Event-driven

D — OTA REPORTING ENGINE (CORNER 5)

OTA Real-Time Reporter

OTA REQ

Corner 5 API client. Real-time B2B
submission. Mutual TLS authentication.

mTLS API TBD

Retry & Resilience

Exponential backoff retries.
At-least-once delivery. Persistent failure
alerts.

Queue-backed

B2C OTA Reporter

CONFIG

Batch or real-time B2C reporting.
High-volume streaming. Timeframe TBD
by OTA.

TBD Timeframe TBD

E — DIGITAL SIGNATURE & QR CODE GENERATION

Signature Application Service

CONFIG

Pluggable XAdES / CAAdES library.
HSM-backed key access. Certificate
chain embed.

XAdES / CAAdES Spec TBD

QR Code Generator

CONFIG

Format TBD by OTA. Content fields TBD.
Configurable template engine — no
rework.

Format TBD Config template

PDF/A-3 Generator

Human-readable invoice output. Embeds
XML attachment. Archival-quality
PDF/A-3.

PDF/A-3 Embedded XML

F — PLATFORM SERVICES

Tenant Management

Onboarding and provisioning. Per-tenant configuration. Billing integration.

Multi-tenant

Message Queue

Kafka for high-volume B2C. RabbitMQ for standard B2B. Decouples ingestion from processing.

Kafka

RabbitMQ

Notification Service

Email / SMS / webhook alerts. Invoice status events. SLA breach notifications.

Email

Webhook

Archive Service

OTA REQ

10–15 year immutable storage. WORM S3-compatible. OTA-compliant archiving.

WORM

Immutable

Taxpayer Portal

Web dashboard. Invoice search, status, history, download. Multi-tenant aware.

React

Portal

4 DATA & STORAGE

Encrypted at rest · Geo-redundant · 10–15 yr retention · Oman/GCC residency

PRIMARY STORES

Invoice Database

OTA REQ

PostgreSQL — AES-256 at rest. Invoice metadata, status, tenant records, RBAC data. Read replicas for analytics.

PostgreSQL

AES-256

XML / Document Object Store

S3-compatible WORM storage. Raw XML payloads. PDF/A-3 attachments.

S3

WORM

Audit Log Store

OTA REQ

Cryptographic hash chain. Every state transition logged. Tamper-evident OTA audit access.

OTA Required

Immutable

OPERATIONAL STORES

Cache Layer

Redis for session data, bloom filters, and rate limits. Sub-millisecond response times.

Redis

Key Management & HSM

OTA REQ

HashiCorp Vault / Cloud KMS. AES-256 and signing keys. HSM-backed production keys.

Vault / KMS

HSM

Backup & DR Service

Cross-region continuous backup. RTO <4hr / RPO <15min. 10–15yr retention match.

DR quarterly

5 INFRASTRUCTURE & OBSERVABILITY

Kubernetes · Multi-AZ · Auto-scaling · 99.9% SLA target

COMPUTE & ORCHESTRATION

Container Platform

Kubernetes with HPA. Multi-AZ deployment. Auto-scaling. Service mesh via Istio.

Kubernetes

Istio

Cloud Platform

Oracle Cloud / AWS / Azure Oman region. Multi-AZ. 99.9% SLA. Data residency: Oman/GCC.

Multi-AZ

Oman residency

SECURITY OPERATIONS

SIEM

OTA REQ

ELK Stack / Splunk. Real-time threat detection. Security event correlation.

OTA Required

ELK / Splunk

SOC / Incident Response

OTA REQ

24/7 monitoring. Detection <1hr. Containment <4hr. OTA notification <24hr.

OTA Required

Vulnerability Scanner

Automated scanning. Scheduled penetration tests. Regular security monitoring.

OTA Evidence

APPLICATION PERFORMANCE MONITORING

APM — Prometheus / Grafana

Latency, throughput, error rates, queue depth, OTA success rate metrics.

Prometheus

Grafana

SLA Reporting

Uptime tracking. P95/P99 latency reports. OTA compliance dashboards. 99.9% target.

99.9% target

ISO 27001:2022 ISMS

OTA REQ

Mandatory OTA accreditation requirement. 14 ISMS control domains. Annual certification audit.

OTA Mandatory

ISO 22301 — Business Continuity

BCP / DR plans. Quarterly DR drills. Business continuity assurance.

BCP / DR

Data Residency & Privacy

OTA REQ

Oman / GCC cloud hosting. Cross-border: must meet OTA conditions. Residency policy documented.

Oman/GCC

Complete Audit Trail

OTA REQ

Every state transition logged. Tamper-evident hash chain. OTA inspector access.

OTA Required

OTA Compliance Monitor

OTA watches ASP KPIs. Internal compliance dashboard. Accreditation risk alerts.

OTA oversight

Risk Management

Risk register and treatment plans. Vendor risk assessment. Board-level reporting.

ISO 27001 Annex A

Architecture Summary — Key Design Decisions

Decision	Description
Multi-tenant SaaS	Row-level isolation. Single platform serving all taxpayer tenants. No per-customer code.
Event-driven pipeline	Message queue decouples ingestion from processing. Guarantees ordering and at-least-once delivery.
Configurable core	Schema, rules, signature standard, and QR content are hot-swappable modules — no downtime updates when OTA publishes final specs.
Corner 2 & 3 dual-role	Acts as both seller ASP and buyer ASP. Same infrastructure, different routing paths.
Data residency	Oman/GCC cloud region. Supports archiving-abroad under OTA conditions.
Horizontal scalability	Kubernetes HPA scales from 100 Phase 1 taxpayers to all VAT-registered entities in Oman.

6

Architecture Layers

40+

Components

4

Configurable Modules

5

OTA Mandatory Controls

<3s

B2B SLA Target

Sources: OTA Service Provider Criteria · OTA Service Provider Portal · Peppol Framework Documentation · ISO/IEC 27001:2022 · Consultation Sessions Dec 2025–Mar 2026